

SIMATS ENGINEERING

ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO2: Foot printing Tools: Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT3)

Name: K.Tejasri

Reg No: 192371019

1. Nmap Scan Analysis

Answer

Analysis of the Scan Results

The Nmap scan on **192.168.1.10** identified the following open ports:

- **Port 22 – SSH**
- **Port 80 – HTTP**
- **Port 3306 – MySQL**

The scan also revealed the operating system and versions of the running services. While this information helps administrators manage the system, it can also help attackers identify weaknesses.

Security Risks

1. SSH (Port 22)

SSH is used for secure remote administration of a system.

Potential Risks

- Weak passwords may allow brute-force attacks.
- Older SSH versions may contain security flaws.
- Unauthorized users may obtain remote access.

Possible Attacks

- Password guessing using automated tools.
- Exploitation of known SSH vulnerabilities.
- Remote system takeover if authentication is compromised.

2. HTTP (Port 80)

HTTP delivers web pages and web applications to users.

Potential Risks

- Data transmitted without encryption.
- Vulnerable web applications may expose sensitive data.
- Improper configurations may reveal confidential files.

Possible Attacks

- SQL Injection
 - Cross-Site Scripting (XSS)
 - Directory Traversal
 - Website Defacement
-

3. MySQL (Port 3306)

MySQL is commonly used to manage application databases.

Potential Risks

- Publicly accessible database service.
- Weak login credentials.
- Exposure of confidential business information.

Possible Attacks

- Database credential brute-force attacks.
 - Theft of customer or business data.
 - Unauthorized modification or deletion of records.
-

Operating System and Version Detection

The scan identified the operating system and service versions.

Security Concern

- Attackers can compare the detected versions with publicly available vulnerability databases to identify exploitable weaknesses.
-

Recommended Security Measures

- Keep all software and services updated.
- Disable unnecessary ports and services.
- Use strong passwords and enable Multi-Factor Authentication (MFA) for SSH.

- Limit MySQL access to trusted systems only.
 - Configure firewall rules to restrict unwanted traffic.
 - Monitor system logs regularly for suspicious activity.
-

Conclusion

The scan results show that important network services are exposed. If these services are not properly secured, attackers may gain unauthorized access, compromise the web application, or steal database information. Proper configuration, regular patching, and continuous monitoring are essential for maintaining system security.

2. GoPhish Phishing Awareness Report

Answer

Report Analysis

The phishing simulation produced the following observations:

- **40%** of employees clicked the phishing link.
- **20%** submitted their usernames and passwords.
- Some employees downloaded the malicious attachment.

These findings indicate that many employees are still vulnerable to phishing and social engineering attacks.

Identified Security Weaknesses

1. Clicking Suspicious Links

A large number of employees trusted fraudulent emails.

Security Impact

- Exposure to malware.
 - Redirection to fake websites.
 - Increased risk of credential theft.
-

2. Entering Login Credentials

Some users entered authentication details on a fake login page.

Security Impact

- User account compromise.
- Unauthorized access to company resources.

- Increased possibility of data breaches.
-

3. Downloading Malicious Attachments

Several employees downloaded unsafe files.

Security Impact

- Malware installation.
 - Ransomware infection.
 - Damage to organizational systems.
-

User Awareness Recommendations

- Organize regular cybersecurity awareness sessions.
 - Train employees to recognize phishing emails.
 - Conduct periodic phishing simulation exercises.
 - Encourage users to verify suspicious emails before responding.
 - Promote immediate reporting of suspicious messages.
-

Email Security Controls

- Enable advanced spam and phishing protection.
 - Configure SPF, DKIM, and DMARC.
 - Automatically scan email attachments.
 - Restrict dangerous file types.
 - Implement URL filtering and email sandboxing.
-

Organizational Policies

- Enforce strong password requirements.
 - Enable Multi-Factor Authentication (MFA).
 - Apply the principle of least privilege.
 - Create a formal incident reporting process.
 - Conduct regular security audits and awareness assessments.
-

Conclusion

The phishing campaign shows that employees remain one of the weakest points in organizational security. Continuous awareness training, secure email filtering, and strong authentication policies can significantly reduce successful phishing attacks.

3. DNS Zone Transfer (Dig Tool) Analysis

Answer

Analysis of the DNS Assessment

The DNS assessment performed using the **Dig** tool showed that the DNS server allows **DNS Zone Transfer (AXFR)** requests. This means an unauthorized user can retrieve the complete DNS zone database.

The information exposed includes:

- Internal hostnames
 - Mail server details
 - DNS records
 - Server names
 - IP addresses
-

Security Implications

Exposed DNS records provide attackers with detailed information about the organization's network.

Possible Risks

- Disclosure of internal infrastructure.
 - Identification of critical servers.
 - Easier network reconnaissance.
 - Increased likelihood of targeted attacks.
-

How Attackers Can Exploit the Information

An attacker may use the exposed records to:

- Create a map of the organization's network.
 - Locate important servers such as mail or database servers.
 - Perform vulnerability scanning on identified systems.
 - Launch targeted phishing campaigns.
 - Plan more advanced cyber-attacks.
-

Best Practices for DNS Security

- Disable DNS Zone Transfers for unauthorized systems.
- Permit AXFR only for trusted secondary DNS servers.
- Configure Access Control Lists (ACLs).
- Remove unnecessary DNS records from public view.
- Enable DNSSEC to ensure DNS authenticity and integrity.
- Regularly monitor DNS logs and configurations.

Conclusion

Allowing unrestricted DNS Zone Transfers exposes valuable network information that can assist attackers during the reconnaissance phase. Restricting AXFR requests, implementing DNSSEC, and regularly reviewing DNS configurations greatly improve the overall security of the DNS infrastructure.